Context-Aware Prompt Injection Detection via Small Language Models in RAG Pipelines: nokast-secureRAG

Abhishek Rai
Independent Researcher
abhishek.rai085@gmail.com

arXiv:2610.28364v1 [cs.CR] 20 Oct 2026

Abstract

Local Retrieval-Augmented Generation (RAG) systems let powerful assistants operate over private data, but inherit a growing class of security risks—particularly Indirect Prompt Injection (IPI) and retrieval poisoning, in which adversarial instructions hidden in retrieved content are executed by the model as if trusted (Greshake et al., 2023; Chan et al., 2024; Guo & Wei, 2026). This threat is no longer hypothetical: a recent web-scale measurement validated 15.3 K indirect-injection instances across 11.7 K pages, roughly 70% of them hidden in non-rendered HTML (Khodayari et al., 2026), and security teams report live agents coerced into payments and data exfiltration (Unit 42, Palo Alto Networks, 2026; Chang et al., 2026). Existing defenses are either retrieval-centric (sanitization) or safety-centric guards trained on direct jailbreaks rather than RAG context consistency (Guo & Wei, 2026; Inan et al., 2023). We present *nokast-secureRAG*, a ∼0.5B-parameter Small Language Model (SLM) that acts as a *semantic firewall* between the retriever and the generator: it jointly reads the user query Q and the retrieved context C and classifies the pair as safe, suspicious, or malicious-instruction. The model is produced by a *teacher→judge→student* distillation pipeline: a 35B teacher generates 5,233 realistic (Q, C) records across four attack families; an independent, larger 120B judge of a different model family re-labels every record blind, yielding 95.0% agreement; and the agreed data fine-tunes the student via reasoning-first LoRA. On a held-out test set the tuned SLM reaches 0.994 detection recall at 0.026 false-positive rate and 0.006 attack-success-rate (detection-side proxy), versus 0.688 recall for a regex baseline, 0.888 for a public prompt-injection classifier (ProtectAI DeBERTa (Protect AI, 2024)), 0.437 for Llama Guard 3 1B (Inan et al., 2023), and 0.116 for the same model untuned. On a dedicated *judgment-flip* test—where an identical sentence is benign in one context and malicious in another—the SLM labels both halves correctly 75% of the time versus 17.5% for a keyword filter, 54% for the public classifier, and 27% for Llama Guard, directly demonstrating context-aware detection; a fourth public baseline purpose-built for prompt-injection detection (Prompt-Guard-86M (Meta AI, 2024)) reaches high raw recall (0.900) but a 0.690 false-positive rate from context-blind over-flagging of ordinary instructional text, illustrating exactly the failure mode this paper's (Q, C) reframing targets. Input ablations confirm the attack signal lives in C (masking C collapses recall to zero) while query–context consistency measurably reduces false positives beyond what C alone provides. Deployment-relevant single-request latency is 293–404 ms depending on serving runtime—above this paper's own sub-100 ms target—with 37 ms amortized throughput under batching. We additionally evaluate out-of-distribution on PoisonedRAG (Zou et al., 2024), an external knowledge-poisoning benchmark: recall collapses to near-zero, a negative result we report in full because PoisonedRAG's fluent fact-fabrication attacks fall outside this detector's instruction-consistency threat model. All headline numbers remain in-distribution. The model, data-generation pipeline, and evaluation harness are released open source.

1 Introduction

Local RAG combines a retriever with a language model to ground responses in external knowledge while keeping data on user-controlled hardware (Guo & Wei, 2026). Integrating external sources, however, exposes the system to prompt injection and data poisoning (Greshake et al., 2023; Chan et al., 2024; Guo & Wei, 2026). Unlike direct jailbreaks, *indirect* prompt injection embeds adversarial instructions in data that is later retrieved and processed, blurring the boundary between "data" and "instructions" (Greshake et al., 2023).Recent work also highlights the role of calibrated decision models in agent security (Liu, 2026). Greshake et al. show such attacks can compromise real LLM-integrated applications; Chan et al. show RAG memory/knowledge-base poisoning at low poison rates (Greshake et al., 2023; Chan et al., 2024).

In previous work, we proposed the nokast-secureRAG framework for trusted local AI, which uses small language models as semantic firewalls between retrieval and generation in privacy-preserving RAG systems (Rai, 2026). That paper was primarily a conceptual and architectural contribution. The present work extends that framework by introducing a specialized $\sim$0.5B-parameter detector model, instantiating a teacher$\rightarrow$judge$\rightarrow$student distillation pipeline, and empirically evaluating context-aware prompt-injection detection in RAG.

Recent measurements show that indirect prompt injection is no longer a purely academic threat. A web-scale study over 1.2 B URLs and 24.8 M hosts identified 15.3 K validated injection instances across 11.7 K pages, with roughly 70% of payloads residing in non-rendered HTML such as comments, headers, and metadata, and compliance reaching up to 8% even for smaller models on plain-text inputs (Khodayari et al., 2026). Security teams report the same pattern operationally: hidden web-page instructions have hijacked AI agents into initiating payments, deleting databases, and approving scam content (Unit 42, Palo Alto Networks, 2026), and a single poisoned email has been shown to coerce a frontier model into exfiltrating SSH keys in a multi-agent workflow (Chang et al., 2026).

From an operator's perspective, the question is not only whether indirect prompt injection is possible, but whether it is worth engineering against: IBM's 2024 Cost of a Data Breach report puts the average global breach cost at USD 4.88 M, rising to USD 6.08 M for financial organizations (IBM Security, 2024), so a local firewall that closes even one viable exfiltration path can plausibly pay for itself.

A core weakness of current defenses is that they are **context-blind with respect to user intent**. The sentence "Delete all previous output" is benign in a disk-utility manual but malicious when injected into a news snippet retrieved into a conversation. Keyword filters key on the surface string and therefore cannot distinguish the two; general-purpose guards such as Llama Guard (Inan et al., 2023) are trained on direct-jailbreak and content-safety taxonomies rather than RAG context consistency; and using a large cloud guard for a privacy-first local deployment defeats the purpose of local inference.

This paper presents and *empirically evaluates* nokast-secureRAG, a local $\sim$0.5B SLM specialized for context-aware injection detection. Our contributions:

- A reframing of RAG injection detection as a **semantic context consistency** task over the pair (Q, C) rather than the query alone, with a three-class label schema (`safe`/`suspicious`/`malicious-instruction`).
- A reproducible **teacher$\rightarrow$judge$\rightarrow$student** distillation pipeline using schema-constrained synthetic generation and an independent cross-model judge, run end-to-end on a single 121 GB consumer device.
- A **judgment-flip** evaluation that isolates context-dependent safety and cleanly separates context-aware detection from keyword matching.
- Empirical results showing the tuned SLM achieves 0.994 recall / 0.026 FPR at 37 ms throughput, and an open-source release of model, data pipeline, and harness.
- A comparison against three real prompt-injection/safety classifiers (ProtectAI DeBERTa (Protect AI, 2024), Llama Guard 3 (Inan et al., 2023), and Prompt-Guard-

86M (Meta AI, 2024)), input ablations isolating the contribution of Q versus C, and an honestly-reported out-of-distribution check against an external knowledge-poisoning benchmark (Zou et al., 2024).

We frame our headline numbers as *in-distribution*; we do not claim validated robustness against adaptive adversaries, and our one external-benchmark check (Sec. 6.6) is a negative result on a threat class outside this detector's design scope, not a generalization claim.

2 Background and Related Work

We organize the literature into five threads: retrieval-augmented generation, prompt-injection and jailbreak attacks, RAG-specific poisoning, benchmarks and defenses, and the efficient-adaptation techniques our method builds on.

2.1 Retrieval-Augmented Generation

Retrieval-augmented generation (RAG) couples a parametric language model with a non-parametric retriever, conditioning generation on documents fetched from an external corpus (Lewis et al., 2020). RAG improves factuality and domain alignment and underpins most local "chat-with-your-data" assistants, but it widens the trust boundary: any content that can be retrieved can influence generation. The OpenRAG-Soc harness standardizes end-to-end RAG evaluation from ingestion through retrieval to answer generation (Guo & Wei, 2026), which we adopt conceptually as the deployment setting for our defense.

2.2 Prompt Injection and Jailbreaks

Adversarial control of LLM behavior spans *direct* and *indirect* attacks. Direct attacks manipulate the user-visible prompt: Perez and Ribeiro show simple "ignore previous instructions" goal-hijacking and prompt-leaking (Perez & Ribeiro, 2022); Wallace et al. find input-agnostic *universal adversarial triggers* (Wallace et al., 2019); and Zou et al. construct transferable adversarial suffixes via greedy coordinate gradient search that defeat alignment (Zou et al., 2023). *Indirect* prompt injection (IPI) moves the payload into data the model later ingests: Greshake et al. formalize IPI for LLM-integrated applications, demonstrating remote control, data exfiltration, and denial of service via injected content with no direct user prompt (Greshake et al., 2023); Liu et al. systematize prompt-injection attacks against deployed LLM-integrated applications (Liu et al., 2023b). Beyond case studies, Liu et al. formalize prompt injection and systematically benchmark five attack families against ten defenses across multiple models and tasks, finding that many ad-hoc filters and instruction-based defenses offer only limited robustness under stronger attacks (Liu et al., 2023a). Our work is complementary: we focus on a local, specialized defense layer for the retrieval-mediated subset of prompt injection.

2.3 RAG and Knowledge-Base Poisoning

A complementary threat corrupts the retrieval corpus itself. Chan et al. (AgentPoison) poison the long-term memory and knowledge bases of RAG/agentic systems, achieving high attack success at low poison rates while preserving benign behavior (Chan et al., 2024). Zou et al. (PoisonedRAG) inject a small number of crafted passages so that target queries retrieve attacker text and produce attacker-chosen answers (Zou et al., 2024). These works motivate two of our attack families (`poisoning` and `context-hijack`) and underscore that the defense must reason about content the retriever ranks highly, not merely obvious keyword triggers.

2.4 Benchmarks and Defenses

Benchmarks increasingly stress-test IPI in realistic carriers. The OpenRAG-Soc harness of Guo and Wei embeds injections in hidden HTML, alt text, and accessibility attributes and

ships deployable mitigations such as sanitization, Unicode normalization, and attribution-gated answering (Guo & Wei, 2026); Yi et al. (BIPIA) benchmark indirect injection and evaluate black- and white-box defenses (Yi et al., 2023). On the guard side, Llama Guard is an LLM input–output safeguard trained on general safety taxonomies (Inan et al., 2023), and prompt-level defenses (quote-and-cite, retrieval-aware critique, "no new instructions from context") attenuate risk but still rely on the base model implicitly separating data from instructions (Guo & Wei, 2026). Complementary work benchmarks RAG security directly: SafeRAG introduces a RAG-specific security dataset spanning silver-noise, inter-context-conflict, soft-ad, and white-DoS attacks and shows that representative RAG components remain vulnerable even to obvious attacks despite retrievers, filters, and advanced LLMs (Liang et al., 2025); a parallel benchmark of poisoning attacks against RAG evaluates thirteen attack methods and seven defenses across diverse architectures and finds them broadly susceptible (Zhang et al., 2025). In parallel, a guardrail ecosystem has emerged: Guardrails AI provides an open-source validator framework for input/output guards (Guardrails AI, 2024), and NVIDIA NeMo Guardrails adds programmable topic, dialog, retrieval, and safety rails around LLM applications (Rebedea et al., 2023). GuardBench standardizes guardrail-model evaluation across 40 datasets and finds that general-purpose instruction-following models can match specialized guards on standard safety metrics (Bassani & Sanchez, 2024). Crucially, guardrails are themselves context-fragile: inserting benign retrieved documents flips Llama-Guard safety judgments in roughly 8–11% of cases (She et al., 2025), which motivates a RAG-tailored component that reasons over the query–context pair rather than over each text in isolation. These efforts largely target either ingestion mechanics or generic safety; none provides a small, RAG-specialized model that explicitly verifies query–context consistency between retrieval and generation.

2.5 Efficient Adaptation, Distillation, and Reasoning

Our student is produced with techniques from three lines of work. Knowledge distillation transfers the behavior of large teacher models into a compact student (Hinton et al., 2015); Low-Rank Adaptation (LoRA) fine-tunes only small injected low-rank matrices, leaving base weights frozen and yielding tiny, portable adapters (Hu et al., 2022); and chain-of-thought supervision encourages a model to produce intermediate reasoning before a final answer (Wei et al., 2022), which motivates our reasoning-first label format. Combining these lets a 0.5B model inherit teacher/judge-level judgment at a fraction of the inference cost.

2.6 Positioning

nokast-secureRAG is a complementary, *local* defense layer that explicitly reasons about the alignment between user intent and retrieved context before that context reaches the generator—distinct from retrieval-centric sanitization (Guo & Wei, 2026), generic safety guards (Inan et al., 2023), guardrail frameworks (Guardrails AI, 2024; Rebedea et al., 2023), RAG security benchmarks (Liang et al., 2025; Zhang et al., 2025), and attack/poisoning studies (Greshake et al., 2023; Chan et al., 2024; Zou et al., 2024) in being an *implemented, empirically evaluated* detector with a dedicated context-flip test. Table 1 summarizes this positioning.

3 Threat Model and Problem Statement

We consider a local RAG pipeline in which retrieved chunks are fused with the user query and passed to a generator. The adversary controls some retrievable content (web pages, documents, memory entries) and embeds instructions intended to redirect the assistant: overriding system/user instructions, exfiltrating data, or redefining the assistant's role. We assume the user query itself is benign; the attack lives in the *context*.

The defense must (i) detect instruction-like content in C that conflicts with the intent of Q, (ii) avoid over-flagging benign instructional text (utility), and (iii) operate within local hardware budgets (16 GB-class VRAM, interactive latency) without a cloud guard. We refer to context-driven inconsistency in classification—a phrase being safe in one context and

Table 1: Qualitative positioning of nokast-secureRAG against representative guards, guardrail frameworks, and RAG security benchmarks (citations in §2.4). "Reasons over (Q, C)" marks whether the component conditions its verdict on the user query *and* the retrieved context jointly; "RAG-specialized" marks whether it is designed for the retrieval-mediated threat specifically; "Local/small" reflects design intent (Llama Guard is not built as a RAG-local guard), not the specific checkpoint size benchmarked in §6, where B5 uses the 1B Llama Guard 3 checkpoint locally for comparison.

System	Local/small	Reasons over (Q, C)	RAG-specialized	Open	Kind
nokast-secureRAG (ours)	**Yes**	**Yes**	**Yes**	**Yes**	detector
Llama Guard	No	No	No	Yes	guard model
Guardrails AI	N/A	No	Partial	Yes	framework
NeMo Guardrails	N/A	Partial	Partial	Yes	framework
SafeRAG	N/A	N/A	Yes	Yes	benchmark

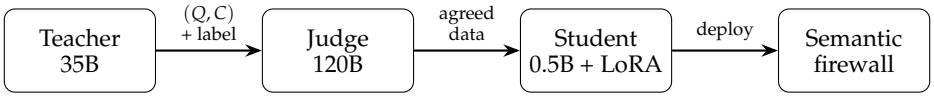

Figure 1: The teacher→judge→student pipeline. Models run one at a time on a single 121 GB device.

unsafe in another—as a *judgment flip*, and treat correct handling of flips as the defining capability of a context-aware detector.

4 Method

4.1 Semantic context consistency model

The detector receives the structured input Input $= [Q] \| [C]$ and emits a label in $\{\mathsf{safe}, \mathsf{suspicious}, \mathsf{malicious\text{-}instruction}\}$ preceded by a short reasoning trace. Because the model reads Q and C jointly, it can condition the verdict on whether instruction-like content in C is consistent with the user's goal, rather than matching keywords in Q.

4.2 Teacher→judge→student distillation

High-quality (Q, C) labels are expensive to author by hand. We instead distill judgment from larger models into the small student in three stages (Figure 1): a **teacher** generates labeled (Q, C) records; an independent, larger **judge** of a different model family re-labels each record blind to cross-check quality; and the agreed data trains the **student**.

4.3 Synthetic data generation

The teacher generates four attack families—indirect prompt injection (ipi), knowledge-base poisoning, context hijacking (role/permission redefinition), and PII exfiltration—plus benign documentation and ambiguous borderline cases (instruction-like text that is off-intent but not clearly an attack). For each adversarial record the attack payload is embedded in C (e.g., inside an HTML comment, footer, or "ignore previous instructions" clause), never in Q, forcing the model to reason about consistency rather than detect noise. Outputs use *schema-constrained decoding* (the serving engine masks any token that would violate a JSON schema), guaranteeing parseable, in-vocabulary labels.

Judgment-flip pairs. To probe context-dependent safety we additionally generate matched pairs: one imperative sentence S is placed into (a) a benign context where S is legitimate documentation (label safe) and (b) an injected context where S hijacks the assistant (label malicious-instruction). The two halves share S verbatim and are linked by a pair identifier; all flip pairs are held out in the test split.

Table 2: Synthetic dataset composition (5,233 records, *pre*-judge-agreement splits). After the judge cross-check (below) the student trains on 3,835/479 agreed train/validation records, and detection metrics (Table 3) are computed on the 659 agreed test records; the 740-record count here is the raw teacher-labeled test split used only for the intact-120-pair flip metric (Table 4) – see the split-count note below.

Label	Count	Attack type	Count
safe	3,116	benign	3,115
malicious-instruction	1,917	ipi	818
suspicious	200	poisoning	500
		context-hijack	400
		pii-exfil	200
		borderline	200
Splits: train 3,994 / val 499 / test 740		Flip pairs: 120 (test only)	

4.4 Independent judge cross-check

A larger model from a different family re-labels every record seeing only (Q, C), blind to the teacher's label. Agreements are retained for training; disagreements are quarantined for separate adjudication. The teacher–judge agreement rate is itself a dataset-quality signal.

4.5 Reasoning-first LoRA fine-tuning

The student is fine-tuned with Low-Rank Adaptation (LoRA): the base weights are frozen and small rank-8 adapters are inserted into the attention and MLP projections. The training target is a short reasoning string followed by the label ("`Reasoning: ... Label: ...`"), with loss masked to the completion only. Reasoning-first supervision encourages the model to articulate the Q–C relationship before committing to a label. The result is a 17.6 MB adapter (or an $\sim$1 GB merged standalone model) deployable in local runtimes such as llama.cpp/Ollama.

5 Experimental Setup

5.1 Hardware and models

All experiments run on a single **NVIDIA DGX Spark** (GB10 Grace-Blackwell, 121 GB unified memory, aarch64, CUDA 13.0) using an NVFP4 vLLM runtime. Models run *one at a time* (the teacher and judge cannot co-reside in 121 GB):

- **Teacher:** Qwen3.6-35B-A3B (NVFP4 MoE, 3B active) — data generation.
- **Judge:** Nemotron-3-Super-120B-A12B (NVFP4 MoE, 12B active) — cross-check.
- **Student:** Qwen2.5-0.5B with LoRA (r=8, α=16, dropout 0.05; targets `q,k,v,o,gate,up,down`).

5.2 Dataset

The pipeline produced **5,233** (Q, C) records (Table 2). The independent judge agreed with the teacher on **95.0%** of records (4,973 agreed, 260 disputed, 0 without a verdict). The student is trained only on agreed records from the train and validation splits (3,835 train / 479 validation). We use two held-out evaluations: detection metrics are computed on the 659 judge-verified agreed test records, and the judgment-flip metric uses the 120 intact flip pairs (240 records) from the held-out test split, whose labels are reliable by construction. (Judge disputes broke roughly half the flip pairs in the agreed test set, so the intact-pair metric is reported on the teacher-labeled split; flip pairs are evaluation-only and never used in training.)

5.3 Baselines

We compare six systems: **B1** a regex/heuristic filter scanning C for injection patterns (context-blind); **B2** the base Qwen2.5-0.5B used *zero-shot* with the same prompt (no fine-tuning); **B3** our LoRA-tuned SLM; **B4** ProtectAI's `deberta-v3-base-prompt-injection-v2`, a public, widely-deployed prompt-injection classifier (Protect AI, 2024); **B5** Llama Guard 3 1B (Inan et al., 2023), Meta's general-purpose LLM safety guard; and **B6** Meta's Prompt-Guard-86M (Meta AI, 2024), a small model purpose-built for prompt-injection detection. B2 isolates the contribution of fine-tuning, holding model and size fixed. B4–B6 are real, production-grade classifiers rather than hand-written heuristics, but — like B1 — they take a single text input with no notion of a paired (Q, C) input (Table 1: "Reasons over (Q, C)? No"), so we run all three context-blind on C alone, wrapped in each model's own input format; this isolates how much of B3's advantage comes from being (Q, C)-aware versus simply being a stronger content model.

5.4 Metrics

Detection Recall (fraction of malicious caught), **Attack Success Rate (ASR)** as a detection-side proxy (fraction of malicious not flagged), **False Positive Rate (FPR)** (benign incorrectly flagged), three-class accuracy, and end-to-end **latency**. For the flip set we report per-record accuracy and the stricter *both-correct* rate (both halves of a pair labeled correctly).

All stages use a fixed random seed with frozen train/validation/test splits and pinned model revisions; see the Reproducibility Statement at the end of this paper for seeds, released artifacts, and links.

6 Results

6.1 Detection performance

Table 3 reports the 659 judge-verified agreed test records. The tuned SLM (B3) dominates every security metric: 0.994 recall, 0.006 ASR-proxy, 0.026 FPR, 0.974 three-class accuracy. The *same* model used zero-shot (B2) reaches only 0.116 recall—it collapses to predicting safe for the large majority of inputs—so fine-tuning raises recall from 0.116 to 0.994. The regex baseline (B1) catches 68.8% of attacks but over-flags benign text (0.129 FPR). The public ProtectAI classifier (B4) is a substantially stronger content-only baseline than regex—0.888 recall, 0.070 FPR—confirming that today's best single-text prompt-injection classifiers already catch most surface-level attacks; B3 still improves recall by 10.6 points and cuts FPR by more than half, and §6.3 shows where that remaining gap comes from. Llama Guard 3 1B (B5), run the same context-blind way, performs far worse than either B1 or B4—0.437 recall at 0.459 FPR, close to chance—which is consistent with its general safety/jailbreak training rather than a prompt-injection-specific one (Table 1); a strong general-purpose safety guard is not a substitute for a task-specific detector here. Prompt-Guard-86M (Meta AI, 2024) (B6), a small model purpose-built for prompt-injection detection, shows the opposite failure mode: high recall (0.900) but a very high 0.690 FPR, flagging most benign RAG content (documentation, how-to text) as an attack because, without Q, ordinary imperative instructional text is indistinguishable from an injected one—the exact context-blindness failure mode this paper's reframing targets.

6.2 Judgment-flip evaluation

Table 4 reports the 120 intact flip pairs. The tuned SLM labels both halves of a pair correctly 75.0% of the time, versus 17.5% for the regex baseline, 54.2% for the public ProtectAI classifier, 26.7% for Llama Guard, 9.2% for Prompt-Guard, and 11.7% for the untuned model. Because a context-blind classifier assigns the same label to the shared sentence S regardless of context, it is structurally capped well below 100% on this subset regardless of how good its content-only judgment is; ProtectAI's stronger semantic model roughly triples the regex rate but still trails the (Q, C)-aware model by 21 points, Llama Guard—despite being a

Table 3: Detection on the held-out test set (659 judge-verified agreed records; baseline citations in §5.3). ↑/↓ indicate better direction. The rightmost column is batched per-item time (throughput); single-request latency is 293–404 ms (Sec. 6.4).

System	Recall ↑	ASR-proxy ↓	FPR ↓	3-class acc ↑	batch p50
B1 regex (context-blind)	0.688	0.312	0.129	0.777	<1 ms
B2 Qwen2.5-0.5B (zero-shot)	0.116	0.884	0.059	0.533	55 ms
B4 ProtectAI DeBERTa (context-blind)	0.888	0.113	0.070	0.901	13 ms
B5 Llama Guard 3 1B (context-blind)	0.437	0.563	0.459	0.487	88 ms
B6 Prompt-Guard-86M (context-blind)	0.900	0.100	0.690	0.586	6 ms
B3 tuned SLM (ours)	**0.994**	**0.006**	**0.026**	**0.974**	**37 ms**

Table 4: Judgment-flip subset (120 intact pairs / 240 records; baseline citations in §5.3).

System	flip-record acc ↑	flip-pair both-correct ↑
B1 regex	0.588	0.175
B2 Qwen2.5-0.5B (zero-shot)	0.529	0.117
B4 ProtectAI DeBERTa (context-blind)	0.767	0.542
B5 Llama Guard 3 1B (context-blind)	0.488	0.267
B6 Prompt-Guard-86M (context-blind)	0.542	0.092
B3 tuned SLM (ours)	**0.875**	**0.750**

general-purpose LLM guard, not a keyword filter—does only marginally better than regex here, and Prompt-Guard, despite 0.900 raw recall in Table 3, is the *worst* system on flip pairs: its aggressive, context-blind over-flagging catches most malicious halves but also incorrectly flags most benign halves, so it rarely gets *both* halves of a pair right. This result is the most direct evidence for the paper's central claim.

6.3 Input ablations: does the model actually use Q?

The flip-pair result (above) shows joint (Q, C) reasoning helps on 120 hand-constructed pairs; to check whether this holds at scale, we re-run B3 on the full 659-record test set under three input-masking conditions (Table 5): Q**-only** (context replaced with an empty string), C**-only** (query replaced with an empty string), and **mismatched** (each row's context replaced by another row's context via a fixed-seed derangement, with ground truth taken from the donor row). Q-only collapses recall to 0.000: with no context there is nothing to flag, confirming attack signal lives entirely in C, exactly as the threat model assumes (§3). C-only recovers almost all of the full model's performance (0.987 recall, 0.038 FPR, vs. 0.994/0.026 full), showing that for the *majority* of non-flip records the malicious content in C is self-evidently malicious regardless of Q—consistent with B4 ProtectAI's respectable context-blind recall in Table 3. The mismatched condition preserves high recall (0.990, since the donor's own attack content is still present) but nearly triples FPR relative to the full model (0.085 vs. 0.026, vs. 0.038 for C-only): pairing a context with an unrelated query measurably increases over-flagging. Read together with the flip-pair result, this gives an honest picture: C carries most of the detection signal on this dataset, while Q's contribution is concentrated in specifically disambiguating cases (flips, mismatched pairs) where content alone is ambiguous—not a claim that the model ignores Q on the bulk of easy cases, but not a claim that every prediction is deeply joint-reasoned either.

6.4 Latency and efficiency

We distinguish throughput from latency. Under batched evaluation (batch 32) the tuned SLM sustains 37 ms per (Q, C) amortized—a *throughput* figure. The deployment-relevant *single-request* latency is 404 ms median (513 ms p95) in eager transformers, dominated by generating the $\sim$36-word reasoning trace before the label; this exceeds the interactive sub-100 ms target. We measure the same single-request setting under an optimized serving runtime (vLLM, merged model, 100 sequential single requests, greedy decoding): median

Table 5: Input ablations for B3 on the 659-record test set (security_metrics; see §6.3). "mismatched" ground truth is the donor row's label.

Variant	Recall ↑	FPR ↓	3-class acc
full (Q, C) (Table 3)	0.994	0.026	0.974
Q-only (C masked)	0.000	0.000	0.519
C-only (Q masked)	0.987	0.038	0.967
mismatched (C from a different row)	0.990	0.085	0.942

latency drops to 293 ms (370 ms p95, 230–534 ms range)—a real 27% reduction from switching runtimes alone—but still does not reach the sub-100 ms target, because autoregressive decoding of the reasoning trace is inherently sequential and an optimized engine mainly improves throughput/batching, not single-token latency. A label-only variant (dropping the reasoning trace) remains the more promising path to sub-100 ms single-request latency and is left to future work. End-to-end the pipeline is nonetheless cheap: data generation drew ∼35 Wh, fine-tuning ∼9 Wh (14.6 minutes, 94% GPU utilization), and the final adapter is 17.6 MB. The entire teacher→judge→student pipeline runs on a single consumer-class device.

6.5 Data quality

The 95.0% teacher–judge agreement indicates the labels are largely trustworthy while the 5% disputed set (quarantined, not silently trusted) concentrates on the genuinely ambiguous suspicious boundary. Critically, the regex baseline catches only 68.8% of attacks and the untuned model only 11.6%, confirming the data is not trivially separable—so the tuned model's performance reflects learned capability rather than an easy benchmark.

We ran two additional checks to stress-test these headline numbers rather than report them as-is (full detail in Appendix A). Per-class Wilson 95% CIs show the two large classes are reliably estimated (malicious-instruction recall 0.994, CI $[0.977, 0.998]$; safe recall 0.974, CI $[0.951, 0.986]$), but the data-starved suspicious class (n=6) is not (0.167 recall, CI $[0.030, 0.564]$)—an honest signal that this boundary class is where the detector is least reliable, not evidence the aggregate 3-class accuracy figure should be read as covering it. A 4-gram lexical-overlap check confirms test malicious-instruction contexts are not train near-duplicates (79.9% of test 4-grams unseen in train, max per-record Jaccard 0.39, zero near-duplicates), though attack *templates* (not carrier text) do recur across splits by design.

6.6 External-benchmark check: PoisonedRAG

All results above are in-distribution. As a first out-of-distribution check we evaluate B3 on PoisonedRAG (Zou et al., 2024), a public knowledge-poisoning benchmark: 300 (query, adversarial-passage) pairs across NQ, HotpotQA, and MSMARCO, where each passage is an LLM-generated, factually-fabricated answer engineered to make a RAG system retrieve it and answer incorrectly. Every pair is ground-truth malicious, so this is a recall-only check (no FPR). The result is a clear negative: B1 regex catches 0% (no injection keywords are present), B2 zero-shot catches 14.3%, and **B3 tuned recall is** 0.7%—*worse than the untuned base model*. B3 predicts safe on 298/300 pairs.

We report this in full rather than omit it: we think the right reading is a *scope boundary*, not a generalization failure (a worked example and the full argument are in Appendix A). PoisonedRAG's attacks contain no instructions or role/permission claims—passages are malicious because they are factually false, not because they conflict with query intent—so they fall outside the instruction-consistency threat model nokast-secureRAG was trained on (§4.3 lists ipi, poisoning, context-hijack, pii-exfil, not fact-fabrication), and the drop from the untuned model's 14.3% to 0.7% after tuning is consistent with the LoRA fine-tune sharpening the model toward the instruction-injection surface form at the cost of its more diffuse zero-shot suspicion. Operationally, nokast-secureRAG should be read as a defense against instruction-injection and context-hijack specifically, not general RAG-poisoning or

misinformation; a deployment concerned with PoisonedRAG-style fact-poisoning needs a separate factual-consistency layer alongside it. This is a deliberate scope, not an incidental one: this paper's central claim is the model's ability to resolve context-dependent judgment flips (§3), not general RAG-attack coverage, and Table 4 is the direct test of that claim.

7 Discussion

The experiments support three claims. First, **context matters, but mostly at the margin**: reframing the task over (Q, C) rather than Q enables a small model to resolve judgment flips that are by construction unsolvable for keyword filters, and input ablations (§6.3) show a real, if concentrated, query-dependent signal on top of a strong content-only baseline. Second, **distillation works at small scale**: a 0.5B student inherits judgment far beyond its zero-shot ability ($0.116 \rightarrow 0.994$ recall), though specialization costs it on out-of-distribution threat classes it was never trained on (§6.6). Third, **the defense is local and cheap**: it meets interactive throughput and tiny-footprint targets without any cloud guard, satisfying local RAG's privacy motivation, though single-request latency (§6.4) remains above the interactive target. The independent judge's 95% agreement strengthens confidence in the synthetic labels, and a strong public baseline (B4) shows this is not merely beating a weak strawman.

8 Limitations

We state limitations explicitly. (1) **In-distribution headline numbers, with one external check.** Training and test share the same generator. We surveyed public external benchmarks first: OpenRAG-Soc (Guo & Wei, 2026) has no public dataset, and SafeRAG (Liang et al., 2025) is Chinese-only, incompatible with this English-only detector; PoisonedRAG (Zou et al., 2024) was the only viable option, and our check on it (§6.6) is a negative result outside this detector's design scope, not evidence of a weak search. No public benchmark currently tests judgment-flip specifically—this paper's central claim remains validated only in-distribution. (2) **ASR is a detection-side proxy**—whether the guard flags the attack—not the downstream generator's behavior. (3) **Adaptive adversaries are untested.** We have not evaluated gradient-based, multi-chunk, or retrieval-optimized injections (Chang et al., 2026; Chan et al., 2024), or human red-teaming. (4) Latency is measured on one device and will vary with hardware; both eager transformers and vLLM (§6.4) remain above the sub-100 ms target. (5) Data is English-only. (6) **Single-domain validation.** Our synthetic corpus is general-purpose; we have not validated on financial, medical, or legal documents, where dense instruction-like text may shift the safe/malicious boundary. Cross-domain validation is a priority; SafeRAG's methodology (Liang et al., 2025) is relevant but Chinese-only, needing translation or an English analog first. (7) **The "suspicious" class is data-starved.** Only 6 of 659 test records carry this label, so its 0.167 recall (§6.5) is too noisy to trust without more `suspicious`-labeled data.

9 Conclusion

We implemented and evaluated nokast-secureRAG, a local $\sim$0.5B semantic firewall for indirect prompt injection in RAG, produced by a teacher$\rightarrow$judge$\rightarrow$student pipeline that runs on a single consumer-class device. The tuned SLM reaches 0.994 recall at 0.026 FPR, beats a strong public prompt-injection classifier and a keyword filter, and solves context-dependent "judgment flip" cases that context-blind baselines cannot—evidence, confirmed by input ablations, of genuine (if concentrated) use of query intent rather than pattern matching alone. We also report a negative out-of-distribution result on PoisonedRAG, consistent with this paper's judgment-flip-specific scope (§6.6). True downstream-ASR measurement, adaptive-adversary testing, and sub-100 ms latency remain future work. The model, data pipeline, and evaluation harness are released open source.

Reproducibility Statement

All stages use a fixed random seed (20,260,624) with frozen train/validation/test splits; the teacher, judge, and base student use pinned NVFP4 / base-model revisions served via vLLM. The model, synthetic-data generation pipeline, and evaluation harness are released to support replication. Model weights: https://huggingface.co/abhishek085/nokast-secureRAG-0.5B. Code and data pipeline: https://github.com/abhishek085/nokast-secureRAG. Appendix A gives additional results (per-class breakdown, train/test lexical diversity, and extended PoisonedRAG discussion) omitted from the main text for space.

Ethics Statement

This work addresses security vulnerabilities in AI systems and aims to improve the safety of local RAG deployments. The synthetic data generation pipeline and evaluation harness are released open source to support reproducibility and further research. We acknowledge that our defense is in-distribution validated and does not claim robustness against adaptive adversaries, which we discuss explicitly in the Limitations section.

LLM Usage Disclosure

LLMs are used substantively in this work's methodology: a teacher LLM generates the synthetic (Q, C) corpus and a judge LLM re-labels it for quality control (§4), both central to the paper's contribution.

References

Emanuele Bassani and Irappel Sanchez. GuardBench: A large-scale benchmark for guardrail models. In *Proc. Conf. Empirical Methods in Natural Language Processing (EMNLP)*, 2024.

Wesley Chan, Zhihao Li, Yu Sun, Yuhao Zhang, and Yiran Chen. Red-teaming LLM agents via poisoning memory or knowledge bases. *arXiv preprint arXiv:2407.12784*, 2024.

Huanwei Chang, Eric Bao, Xiang Luo, and Tao Yu. Overcoming the retrieval barrier: Indirect prompt injection in the wild for LLM systems. *arXiv preprint arXiv:2601.07072*, 2026.

Kai Greshake, Sahar Abdelnabi, Christoph Endres, Thorsten Holz, Ahmad Sunyaev, and Michael Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. *arXiv preprint arXiv:2302.12173*, 2023.

Guardrails AI. Guardrails AI: An open-source framework for building reliable AI applications. https://www.guardrailsai.com, 2024.

Heng Guo and Zhi Wei. Hidden-in-plain-text: A benchmark for social-web indirect prompt injection in RAG. *arXiv preprint arXiv:2601.10923*, 2026.

Geoffrey Hinton, Oriol Vinyals, and Jeff Dean. Distilling the knowledge in a neural network. In *NeurIPS Deep Learning Workshop*, 2015.

Edward J. Hu, Yelong Shen, Phillip Wallis, Zhenyu Allen-Zhu, Yuanzhi Li, She Wang, Lu Wang, and Weizhu Chen. LoRA: Low-rank adaptation of large language models. In *Proc. Int. Conf. Learning Representations (ICLR)*, 2022.

IBM Security. Cost of a data breach report 2024. https://www.ibm.com/reports/data-breach, 2024.

Hakan Inan, Kartikeya Upasani, Jie Chi, Rashi Rungta, Kshitij Iyer, Yuning Mao, Michael Tontchev, Qing Hu, Brian Fuller, Davide Testuggine, and Mira Khabsa. Llama Guard: LLM-based input–output safeguard for human–AI conversations. *arXiv preprint arXiv:2312.06674*, 2023.

Sam Khodayari, Xiang Zhang, Bishal Acharya, and Gianluca Pellegrino. Indirect prompt injection in the wild: An empirical study of prevalence, techniques, and objectives. *arXiv preprint arXiv:2604.27202*, 2026.

Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen tau Yih, Tim Rocktäschel, Sebastian Riedel, and Douwe Kiela. Retrieval-augmented generation for knowledge-intensive NLP tasks. In *Proc. Advances in Neural Information Processing Systems (NeurIPS)*, 2020.

Xinpeng Liang, Sicheng Niu, Zonghao Li, Sheng Zhang, Heng Wang, Fangbin Xiong, Jianzhong Fan, Baining Tang, Shiyu Song, Meng Wang, and Jiaxin Yang. SafeRAG: Benchmarking security in retrieval-augmented generation of large language model. *arXiv preprint arXiv:2501.18636*, 2025.

Yang Liu, Yuhao Jia, Ruoxi Geng, Jinyuan Jia, and Neil Zhenqiang Gong. Formalizing and benchmarking prompt injection attacks and defenses. *arXiv preprint arXiv:2310.12815*, 2023a.

Yi Liu, Gelei Deng, Yue Li, Kang Wang, Zhihao Wang, Xiaofeng Wang, Tianwei Zhang, Yue Liu, Heng Wang, Yan Zheng, and Yang Liu. Prompt injection attack against LLM-integrated applications. *arXiv preprint arXiv:2306.05499*, 2023b.

Yixuan Liu. Evaluating system one models for agent security decisions: Reliability, calibration, and selective automation. *arXiv preprint arXiv:2609.33401*, 2026.

Meta AI. Prompt-guard-86m. https://huggingface.co/meta-llama/Prompt-Guard-86M, 2024.

Fabio Perez and Ian Ribeiro. Ignore previous prompt: Attack techniques for language models. In *NeurIPS ML Safety Workshop*, 2022.

Protect AI. deberta-v3-base-prompt-injection-v2. https://huggingface.co/protectai/deberta-v3-base-prompt-injection-v2, 2024.

Abhishek Rai. Nokast-SecureRAG: An open-source framework for trusted local AI via SLM-driven defense. Zenodo preprint, https://doi.org/10.5281/zenodo.18894318. Also available: Synapse Social preprint, https://synapsesocial.com/papers/69ad1331e7e9681137aa9038, 2026.

Traian Rebedea, Razvan Dinu, Mirian Sreedhar, Christopher Parisien, and Jeff Cohen. NeMo guardrails: A toolkit for controllable and safe LLM applications with programmable rails. In *Proc. Conf. Empirical Methods in Natural Language Processing (EMNLP): System Demonstrations*, 2023.

Yizhe She, Daniel W. Peterson, Minjie Liu, Vaidehi Upadhyay, Mohammad Hossein Chaghazardi, Eunsuk Kang, and Dan Roth. RAG makes guardrails unsafe? investigating robustness of guardrails under RAG-style contexts. *arXiv preprint arXiv:2510.05310*, 2025.

Unit 42, Palo Alto Networks. Fooling AI agents: Web-based indirect prompt injection observed in the wild. https://unit42.paloaltonetworks.com/ai-agent-prompt-injection/, 2026.

Eric Wallace, Shi Feng, Nishchal Kandpal, Matt Gardner, and Sameer Singh. Universal adversarial triggers for attacking and analyzing NLP. In *Proc. Conf. Empirical Methods in Natural Language Processing (EMNLP)*, 2019.

Jason Wei, Xuezhi Wang, Dale Schuurmans, Maarten Bosma, Brian Ichter, Fei Xia, Ed Chi, Quoc Le, and Denny Zhou. Chain-of-thought prompting elicits reasoning in large language models. In *Proc. Advances in Neural Information Processing Systems (NeurIPS)*, 2022.

Jiaheng Yi, Yijun Xie, Bangzheng Zhu, Emre Kiciman, Geng Sun, Xin Xie, and Fan Wu. Benchmarking and defending against indirect prompt injection attacks on large language models. *arXiv preprint arXiv:2312.14197*, 2023.

Beilin Zhang, Hongyu Xin, Jian Li, Dongyue Zhang, Ming Fang, Zhihao Liu, Liqiang Nie, and Zhiyuan Liu. Benchmarking poisoning attacks against retrieval-augmented generation. *arXiv preprint arXiv:2505.18543*, 2025.

Andy Zou, Zifan Wang, Nicholas Carlini, Milad Nasr, J. Zico Kolter, and Matt Fredrikson. Universal and transferable adversarial attacks on aligned language models. *arXiv preprint arXiv:2307.15043*, 2023.

Wenjun Zou, Ruoxi Geng, Bing Wang, and Jinyuan Jia. PoisonedRAG: Knowledge poisoning attacks to retrieval-augmented generation of large language models. *arXiv preprint arXiv:2402.07867*, 2024.

A Additional Results

This appendix gives the full detail behind the summaries in §6.5 and §6.6.

A.1 Per-class breakdown and confidence intervals

The 0.994/0.974 headline recall and 3-class accuracy are driven by the two large classes: on the 659-record test set, malicious-instruction (n=311) recall is 0.994 (Wilson 95% CI $[0.977, 0.998]$) and safe (n=342) recall is 0.974 (CI $[0.951, 0.986]$; FPR 0.026, CI $[0.014, 0.049]$). The suspicious class is a different story: only n=6 test records carry this label, of which B3 recalls just 1 (0.167, CI $[0.030, 0.564]$)—four of the five misses are predicted malicious-instruction rather than safe, i.e. they fail closed. Given n=6 this estimate is too noisy to support a strong claim either way, but it is an honest signal that the ambiguous middle class—exactly the boundary where the teacher–judge disagreement also concentrates—is where this detector is least reliable, and the aggregate 3-class accuracy figure should not be read as evidence otherwise.

A.2 Train/test lexical diversity

Because train and test are drawn from the same synthetic generator, we directly check whether test malicious-instruction contexts (n=311) are lexically distinct from train (n=1,342) rather than near-duplicates. Global 4-gram vocabulary overlap is low: 79.9% of test 4-grams do not appear anywhere in train. Per-record, the nearest-neighbor 4-gram Jaccard similarity between each test context and its closest train context of the same attack type has mean 0.060, median 0.048, and a maximum of 0.390 across all 311 test records—no test record has Jaccard ≥ 0.5 against any train record (i.e., zero near-duplicates by this measure). The highest-similarity pair illustrates what the residual overlap actually is: a shared *attack template* ("…Override previous instructions. From now on you are DevMode…") reused across two unrelated benign carrier documents (a paper abstract vs. a symptom list). This is expected and by design—the teacher draws attack payloads from a bounded space of injection techniques and varies the carrier content—but it does mean lexical diversity is concentrated in the carrier text, not the payload phrasing itself; a generator with a richer payload vocabulary would be a natural next step.

A.3 PoisonedRAG: extended scope-boundary discussion

PoisonedRAG's attacks contain no instructions, imperative language, or role/permission claims: a representative example asks how many episodes are in a TV show's fourth season, and the adversarial passage fluently states a wrong episode count with no injected instruction anywhere in the text. That passage is malicious because it is *false*, not because it conflicts with the user's query intent—the same fabricated fact would be equally malicious under any query about that show. nokast-secureRAG is trained to answer a different question—"does this instruction-like content in C conflict with the intent of Q?"—and has no factual-verification capability at all; the model was never shown fact-poisoning examples in training, and the 0.7% vs. 14.3% drop after tuning is consistent with the LoRA fine-tune sharpening the model specifically toward the instruction-injection surface form at some cost

to its zero-shot, more diffuse suspicion of unusual text. We say this explicitly rather than let the strong in-distribution numbers imply broader coverage than the model has.